



ANEXO

Questionário para mensuração do grau de adoção das boas práticas
de gestão e governança de TI

Introdução

O TCE-RJ, por meio da Coordenadoria de Auditoria em Políticas de Tecnologia da Informação (CAD-TI), está realizando a fiscalização 18/2026 que tem por objetivo avaliar o grau de adoção das organizações públicas às boas práticas de governança e gestão de TI.

O método utilizado é o de autoavaliação de controles internos (do inglês *Control Self-Assessment* – CSA), no qual disponibiliza-se um questionário eletrônico estruturado em boas práticas de governança e gestão de tecnologia da informação, referenciais nacionais e internacionais e normativos aplicáveis à Administração Pública, incluindo aspectos relacionados à segurança cibernética, gestão de serviços, continuidade, gestão de riscos, inteligência artificial, estrutura organizacional e gestão de soluções e projetos de TI.

O questionário busca levantar informações sobre a situação atual da organização quanto às práticas avaliadas, permitindo identificar capacidades institucionais, riscos, fragilidades, iniciativas existentes e oportunidades de melhoria. Além do preenchimento das respostas, serão solicitadas evidências documentais que poderão ser analisadas pela equipe de auditoria para corroborar as informações prestadas.

A organização deverá preencher a versão *on-line* deste questionário, conforme instruções a seguir. Com o recebimento do termo, a equipe de auditoria encaminha ao responsável designado o *link* com a versão *on-line* do questionário, assim como seu código de acesso, que é pessoal e intransferível.

Antes de iniciar o preenchimento *on-line*, recomenda-se que o servidor responsável colete todas as informações necessárias em colaboração com as áreas de Tecnologia da Informação, Segurança da Informação e outras áreas relevantes.

A responsabilidade pelas respostas dadas ao questionário é do dirigente máximo da organização, com base nas respostas providas pelas áreas relacionadas.

Observações importantes:

- 1) As informações consolidadas poderão ser utilizadas pelo TCE-RJ para elaboração de diagnósticos, indicadores, análises comparativas, painéis e relatórios de fiscalização, observadas as restrições legais e institucionais aplicáveis.
- 2) O questionário não possui caráter exaustivo. Algumas práticas avaliadas podem não ser aplicáveis à realidade, ao porte, à estrutura ou ao contexto específico de determinadas organizações.
- 3) Para os itens que exigem submissão de evidências documentais, estas poderão ser analisadas pela equipe de auditoria para validação das respostas fornecidas. Para os demais itens, as evidências devem ser mantidas organizadas e disponíveis para futura solicitação do TCE-RJ.

- 4) Para os itens que exigem submissão de evidências documentais são sugeridos exemplos de documentos que possam comprovar a adoção da prática medida. Assim, não é exigido que sejam enviados todos os documentos da relação.
- 5) Informa-se que, para os itens que exigem anexos, será permitido o upload de apenas um arquivo nos formatos PDF, ZIP ou DOCX, com tamanho máximo de 10 MB. Caso a organização deseje enviar mais de um documento, recomenda-se que todos sejam compactados em um único arquivo ZIP.

As definições associadas a cada categoria de resposta são as seguintes:

Nível de adoção da prática	Definição
Não adota	<u>A organização se enquadra em uma das seguintes situações:</u> a) não adota a prática; b) não discutiu acerca da adoção da prática; c) discutiu sobre a adoção da prática, mas ainda não há decisão expressa para adotá-la.
Há decisão formal ou plano aprovado para adotá-lo	<u>A organização se enquadra em uma das seguintes situações:</u> a) decidiu expressamente adotar a prática; b) iniciou a elaboração de um plano de ação que abrange o processo, o cronograma e os responsáveis pela implementação da prática (existem esboços do plano de ação ou parte dele); c) concluiu e aprovou a versão final do plano de adoção da prática, mas ainda não iniciou sua implementação; d) adota a prática em estudo experimental ou piloto.
Adota em menor parte	<u>A organização se enquadra em uma das seguintes situações:</u> a) adota a prática: • de forma assistemática (informal, depende do setor/pessoa que conduz a atividade ou chefia a unidade); • de forma sistemática (padronizada e periódica) em pequena parte da organização (em até 15% da organização); • de forma sistemática (padronizada e periódica) para pequena parte dos colaboradores e/ou gestores (para até 15% dos colaboradores e/ou gestores); • de forma sistemática (padronizada e periódica) em pequena parte das situações em que sua aplicação é possível (em até 15% das situações). b) em caso de documento (p. ex.: política, estratégia, plano, catálogo), o documento não está vigente ou não está atualizado; c) em caso de modelo, estrutura ou programa, pequena parte dos seus elementos foram implementados (até 15%).

Nível de adoção da prática	Definição
Adota parcialmente	<u>A organização se enquadra em uma das seguintes situações:</u> a) adota a prática: • de forma sistemática (padronizada e periódica) para parte da organização (de 15% a 85% da organização); • de forma sistemática (padronizada e periódica) para parte dos colaboradores e/ou gestores (para 15% a 85% dos colaboradores e/ou gestores); • de forma sistemática (padronizada e periódica) em parte das situações em que sua aplicação é possível (em 15% a 85% das situações). b) em caso de documento (p. ex.: política, estratégia, plano, catálogo), o documento está vigente e atualizado, mas não contempla ou contempla pequena parte dos requisitos apresentados nas questões adicionais de múltipla escolha (caso sejam apresentadas pelo sistema); c) em caso de modelo, estrutura ou programa, parte dos seus elementos foram implementados (15% a 85% dos elementos). <u>Obs:</u> Poderão ser apresentadas questões adicionais do tipo múltipla escolha, para detalhamento da resposta.
Adota em maior parte ou totalmente	<u>A organização se enquadra em uma das seguintes situações:</u> a) adota a prática: • de forma sistemática (padronizada e periódica) para grande parte da organização (em mais de 85% da organização) ou na totalidade da organização; • de forma sistemática (padronizada e periódica) para grande parte dos colaboradores e/ou gestores (para mais de 85% dos colaboradores e/ou gestores) ou para a totalidade dos colaboradores e/ou gestores; • de forma sistemática (padronizada e periódica) em grande parte das situações em que sua aplicação é possível (em mais de 85% das situações) ou na totalidade das situações em que sua aplicação é possível. b) em caso de documento (p. ex.: política, estratégia, plano, catálogo), o documento está vigente, atualizado e contempla todos ou a maior parte dos requisitos apresentados nas questões adicionais de múltipla escolha (caso sejam apresentadas pelo sistema); c) em caso de modelo, estrutura ou programa, grande parte dos seus elementos foram implementados (mais de 85% dos elementos). <u>Obs:</u> Poderão ser apresentadas questões adicionais do tipo múltipla escolha, para detalhamento da resposta.

Nível de adoção da prática	Definição
Não se aplica	A Organização entende que a prática não se aplica a sua realidade, selecionando três possíveis opções com as seguintes interpretações: <u>Não se aplica porque há lei ou norma externa à organização que impede a implementação desta prática</u> - A organização discutiu acerca da adoção da prática e decidiu não a adotar, tendo em vista a existência de lei ou norma, externa à organização, que restringe ou veda a sua adoção. Nesse caso, para a resposta ser considerada válida, o respondente deveria apontar, em campo adicional apresentado pelo sistema, o motivo e os fundamentos legais que impedem a adoção da prática. Foi alertado que normativos internos e outros normativos que possam ser adaptados pelas instâncias internas de governança para melhor aplicação na organização não deveriam ser utilizados como justificativa para a marcação dessa alternativa; <u>Não se aplica porque há estudo(s) que demonstra(m) que o custo de implementar esta prática é maior que o benefício que seria obtido dessa implementação</u> - A organização discutiu acerca da adoção da prática e decidiu não a adotar, tendo em vista a existência de estudo de viabilidade que concluiu que o custo-benefício de sua adoção é desfavorável para a sociedade e para a organização. Nesse caso, para a resposta ser considerada válida, o respondente deveria indicar, em campo adicional apresentado pelo sistema, trabalhos e documentos que evidenciem a realização do estudo de viabilidade; e <u>Não se aplica por outras razões</u> - A organização discutiu acerca da adoção da prática e decidiu não a adotar, tendo em vista a existência de outras razões que impedem a adoção da prática no contexto da organização. Nesse caso, para a resposta ser considerada válida, o respondente deveria apontar, em campo adicional apresentado pelo sistema, as razões pelas quais considera que a prática não é aplicável no contexto da organização.

RESUMO DAS INSTRUÇÕES

- 1) O TCE-RJ envia e-mail ao ponto focal designado pela Administração com as informações de acesso ao Questionário *on-line*.
- 2) O ponto focal coleta todas as informações necessárias para preenchimento do questionário junto às áreas, acessa o Questionário *on-line*, responde com as informações previamente levantadas e o submete.

Em caso de dúvidas no preenchimento ou qualquer informação adicional, favor enviar *e-mail* para auditoriati@tcerj.tc.br ou entrar em contato com um dos seguintes auditores da CAD-TI, pelo telefone (21) 3231-5293:

- Augusto César Benvenuto de Almeida;
- João Paulo de Freitas Ramirez.

Estrutura Organizacional e Força de Trabalho

0101. Qual alternativa melhor descreve a formalização e o modelo de operação predominante da Tecnologia da Informação (TI) na organização?

Identifica se a TI existe formalmente no organograma e como os recursos e serviços tecnológicos estão distribuídos física e administrativamente na organização.

- ☐ a) Centralizada Interna: Há uma área de TI centralizada e formal que atende toda a organização, utilizando equipe técnica majoritariamente própria (servidores).
- ☐ b) Centralizada Terceirizada: Há uma área de TI centralizada e formal que faz a gestão, mas a execução operacional/técnica é predominantemente terceirizada (ex: fábricas de software, service desk).
- ☐ c) Centralizada Externa: Os serviços de TI são prestados predominantemente por um órgão, entidade ou estrutura central externa à organização (ex: empresa pública de processamento de dados estadual ou municipal).
- ☐ d) Descentralizada: Diferentes secretarias, unidades ou setores possuem autonomia e mantêm suas próprias equipes, contratos ou infraestruturas de TI de forma independente.
- ☐ e) Híbrida: Existe uma TI central formal para diretrizes e infraestrutura corporativa, mas as áreas de negócio possuem equipes próprias para sustentar sistemas específicos.
- ☐ f) Inexistente / Informal: Não há área de TI formalmente instituída no organograma da organização.

? Considere o modelo predominante de organização e prestação dos serviços de TI da própria organização, ainda que existam situações pontuais diferentes em determinadas secretarias, unidades ou sistemas. No âmbito do SETIC, a atuação do PRODERJ como órgão diretor do sistema e provedor de diretrizes corporativas não caracteriza, por si só, modelo híbrido, federado ou centralizado externo. A classificação deve considerar principalmente como a própria organização estrutura, executa, gerencia e operacionaliza suas atividades e serviços de TI.



Evidência documental

Forneça como evidência a lei, decreto, portaria, regimento interno, organograma, contrato, convênio, termo de cooperação ou instrumento equivalente que demonstre o modelo de organização e prestação dos serviços de TI.

0102. Como a área de tecnologia da informação está posicionada na estrutura hierárquica da organização?

Identifica o nível hierárquico da área de TI e sua proximidade com a alta administração, o que pode influenciar sua capacidade de coordenação institucional, priorização de demandas e participação nas decisões estratégicas.

- ☐ a) a área de TI reporta-se diretamente ao dirigente máximo da organização
- ☐ b) a área de TI está subordinada a secretaria, subsecretaria, diretoria-geral ou estrutura equivalente de nível estratégico
- ☐ c) a área de TI está subordinada a área administrativa, financeira ou área meio equivalente
- ☐ d) a área de TI está subordinada a unidade operacional ou setorial sem atuação corporativa relevante
- ☐ e) não há área de TI formalmente instituída ou não há posicionamento hierárquico formal definido para a área de TI

? Considere a posição formal predominante da unidade central de TI no organograma institucional.



Evidência documental

Forneça como evidência o organograma institucional, regimento interno, lei, decreto, portaria ou instrumento equivalente que demonstre a posição hierárquica da área de TI.

0103. A organização definiu formalmente as atribuições e competências da área de tecnologia da informação.

As atribuições da área de TI correspondem às competências, responsabilidades e atividades formalmente estabelecidas em norma, regimento, organograma, ato administrativo ou instrumento equivalente.

- ☐ a) a área de TI possui atribuições formalizadas relacionadas à sustentação de infraestrutura e serviços tecnológicos
- ☐ b) a área de TI possui atribuições formalizadas relacionadas ao desenvolvimento, manutenção ou integração de sistemas
- ☐ c) a área de TI possui atribuições formalizadas relacionadas à segurança da informação ou segurança cibernética
- ☐ d) a área de TI possui atribuições formalizadas relacionadas à governança, planejamento ou gestão de tecnologia da informação
- ☐ e) a área de TI possui atribuições formalizadas relacionadas à gestão de contratos e fornecedores de tecnologia da informação
- ☐ f) a área de TI possui atribuições formalizadas relacionadas à gestão de dados, análise de dados, automação ou inteligência artificial
- ☐ g) não há atribuições ou competências da área de TI formalmente definidas em norma, regimento, organograma, ato administrativo ou instrumento equivalente

? Considere apenas atribuições formalmente definidas em instrumentos institucionais. Não considere atividades exercidas apenas de forma informal ou ad hoc.



Evidência documental

Forneça evidência das atribuições formalizadas da área de TI, como: regimento interno; decreto; resolução; portaria; manual de competências; descrição formal de responsabilidades; ou outras evidências cabíveis.

0104. Como a função de Segurança da Informação (SI) está formalmente posicionada na estrutura organizacional?

Identifica se a segurança da informação possui unidade, gestor, responsável, comitê ou instância formal, e se está integrada à TI, separada da TI ou organizada em estrutura colegiada.

- ☐ a) Independente da TI: Há unidade, área ou gestor de segurança da informação formalmente separado da área de TI.
- ☐ b) Integrada à TI: A área, equipe ou responsável por segurança da informação integra a estrutura da área de tecnologia da informação.
- ☐ c) Gerida por Comitê: Não há uma unidade administrativa exclusiva para SI, mas a função é coordenada por comitê, comissão ou instância colegiada formal.
- ☐ d) Responsável designado: Há responsável formalmente designado para segurança da informação, mas sem unidade, equipe ou comitê específico.
- ☐ e) Inexistente / Informal: Não há área, função, gestor ou comitê de Segurança da Informação formalmente instituído na organização.



Evidência documental

Forneça como evidência o organograma normatizado ou a portaria de designação que demonstre a quem o gestor/comitê de Segurança da Informação está subordinado.

0105. Informe o quantitativo de profissionais que atuam regularmente em tecnologia da informação e segurança da informação, por área e tipo de vínculo.

Esta questão permite avaliar a capacidade operacional da entidade, o grau de dependência de força de trabalho externa e a existência de pessoal dedicado às funções de TI e segurança da informação.

	Servidores efetivos ou empregados públicos	Ocupantes exclusivamente de cargos em comissão (sem vínculo efetivo)	Profissionais terceirizados ou contratados por empresas prestadoras de serviço	Servidores cedidos ou requisitados de outros órgãos	Contratados por tempo determinado (ex: Processo Seletivo Simplificado - PSS)	Estagiários e bolsistas
Tecnologia da Informação						
Segurança da Informação						

? Informe valores numéricos inteiros. Considere profissionais que atuam de forma regular em atividades de TI ou segurança da informação, na unidade central ou em estruturas descentralizadas. Caso uma pessoa atue simultaneamente nas duas áreas, registre-a na área em que atua predominantemente. Caso não haja profissionais em determinada combinação, informe 0.

Governança de Tecnologia da Informação

Este grupo avalia como a alta administração direciona, acompanha e avalia o uso da tecnologia da informação na organização. A governança de TI não se limita a aspectos técnicos: envolve decisões estratégicas sobre como a tecnologia deve apoiar os objetivos institucionais, melhorar os serviços públicos, reduzir riscos e gerar valor para a sociedade.

Nesse contexto, espera-se que a alta administração estabeleça diretrizes claras para a TI, assegure o alinhamento entre a estratégia institucional e a estratégia de tecnologia da informação, defina responsabilidades e participe das decisões sobre investimentos, projetos e prioridades. Também se espera a atuação de instâncias de governança, como comitês ou estruturas equivalentes, quando aplicável.

A governança de TI também envolve o monitoramento do desempenho da gestão de TI, a supervisão de riscos relevantes, o uso de informações gerenciais para a tomada de decisão e a avaliação dos benefícios entregues pelas iniciativas de tecnologia. Esses mecanismos devem ser apoiados por práticas de controle, auditoria interna, transparência e prestação de contas.

Uma governança de TI efetiva contribui para o uso eficiente dos recursos públicos, evita desperdícios, fortalece a continuidade e a qualidade dos serviços digitais e apoia a entrega de serviços públicos mais simples, seguros e centrados no usuário.

1001. A alta administração estabeleceu modelo de gestão de tecnologia da informação.

O modelo de gestão de tecnologia da informação é o conjunto de diretrizes, estruturas, papéis e instâncias (como comitês) definidos pela alta administração para orientar, controlar e alinhar a TI às estratégias organizacionais.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização define as diretrizes para o planejamento de tecnologia da informação
- ☐ b) a organização define as diretrizes para gestão de riscos de tecnologia da informação
- ☐ c) a organização define os papéis e responsabilidades da área de gestão de tecnologia da informação
- ☐ d) a organização designa responsáveis de cada área de negócio para a gestão dos respectivos sistemas informatizados
- ☐ e) a organização dispõe de comitê de tecnologia da informação composto por representantes de áreas relevantes da organização
- ☐ f) o comitê de tecnologia da informação realiza as atividades previstas em ato constitutivo
- ☐ g) a organização define as diretrizes para avaliação do desempenho dos serviços de tecnologia da informação
- ☐ h) a organização estabeleceu objetivos, indicadores e metas para a gestão de tecnologia da informação
- ☐ i) a organização divulga os objetivos, indicadores e metas para a gestão de tecnologia da informação

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Área de gestão de tecnologia da informação; Área de negócio; Atividades; Comitê de tecnologia da informação; Diretriz; Estabelecer; Gestão; Gestão de riscos; Modelo; Organização; Planejamento de TI; Sistema informatizado ou sistema automatizado; TI (Tecnologia da Informação).



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do modelo formal de gestão de TI, como: política ou norma de governança de TI aprovada pela alta administração; regimento do comitê de TI e atas que comprovem sua atuação; organograma com papéis e responsabilidades; designação formal de gestores de sistemas; diretrizes de planejamento, riscos e desempenho de TI; documentos com objetivos, indicadores e metas de TI; ou outras evidências cabíveis.

1002. A alta administração monitora o desempenho da gestão de tecnologia da informação.

O monitoramento do desempenho de TI é o acompanhamento sistemático, pela alta administração, de indicadores, metas e resultados da gestão de TI, para avaliar desempenho e orientar decisões.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) rotinas de monitoramento do desempenho da gestão de tecnologia da informação estão definidas
- ☐ b) há acompanhamento na execução dos planos vigentes quanto ao alcance das metas estabelecidas
- ☐ c) os indicadores de desempenho da gestão de tecnologia da informação estão implantados (há coleta e análise dos dados necessários à medição de desempenho)
- ☐ d) relatórios de medição de desempenho da gestão de tecnologia da informação estão disponíveis à liderança

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Área de gestão de tecnologia da informação; Gestão do desempenho; Indicador; Indicador de desempenho; Meta; Monitoramento da estratégia; Monitorar o desempenho; TI (Tecnologia da Informação).



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do monitoramento do desempenho de TI, como: norma ou procedimento que estabeleça rotinas de monitoramento; painel ou sistema com indicadores e metas de TI; relatórios periódicos de desempenho; atas de reuniões da alta administração ou comitê de TI com análise de resultados; evidências de acompanhamento do plano de TI; ou outras evidências cabíveis.

1003. A instância superior de governança recebe serviços de auditoria interna que adicionam valor à organização.

Os serviços de auditoria interna agregam valor quando avaliam riscos, controles e governança, apoiando a alta administração com recomendações para melhoria da gestão, inclusive de TI e segurança da informação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) os serviços de auditoria interna prestados anualmente para a organização contemplam avaliação da gestão de tecnologia da informação
- ☐ b) os serviços de auditoria interna prestados anualmente para a organização contemplam avaliação da gestão de segurança da informação

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Adicionar/criar valor; Área de gestão de tecnologia da informação; Auditoria interna; Conselho ou Colegiado Superior / instância superior; Informação; Processos de governança; Risco; Risco crítico; Segurança da Informação; Serviços de auditoria; TI (Tecnologia da Informação).



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência dos serviços de auditoria interna, como: plano anual de auditoria baseado em riscos; relatórios de auditoria que abranjam governança, riscos críticos, TI e segurança da informação; pareceres sobre confiabilidade das prestações de contas; atas ou comunicações à instância superior; evidências de acompanhamento das recomendações; ou outras evidências cabíveis.

1004. A organização definiu metas para a simplificação do atendimento prestado aos usuários dos serviços públicos.

As metas de simplificação do atendimento são objetivos definidos para ampliar serviços digitais, reduzir burocracia e melhorar a experiência do usuário nos serviços públicos.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) há metas para a ampliação da oferta de serviços públicos prestados em meio digital
- ☐ b) há metas com vistas à eliminação da exigência de atestados, certidões ou outros documentos comprobatórios que constem em base de dados oficial da administração pública federal, como condição para a prestação de serviços
- ☐ c) há metas para reduzir a necessidade de atendimento presencial dos usuários em todas as etapas de prestação dos serviços públicos (p. ex.: por meio da automação completa das etapas de: solicitação, acompanhamento de solicitações, execução de procedimentos e comunicação de resultados)
- ☐ d) há metas voltadas à melhoria e ao incremento da atuação integrada e sistêmica com outros órgãos e entidades dos quais dependa ou com os quais interaja intensivamente na prestação dos serviços públicos, tais como metas de compartilhamento de dados e metas de interoperabilidade relacionadas à adoção de procedimentos, ferramentas e plataformas comuns (p. ex.: Plataforma de Cidadania Digital)
- ☐ e) há metas com vistas a otimizar o uso de múltiplos canais de atendimento (p. ex.: canal presencial, telefone, canal digital/internet, aplicativos móveis, correio eletrônico etc.), de modo a assegurar que canal adequado esteja disponível para usuários com necessidades especiais e, no caso de serviços críticos e relevantes, que canais alternativos estejam disponíveis, se falhar o canal principal
- ☐ f) a organização utiliza a gestão de riscos como instrumento para promover a simplificação de procedimentos associados à prestação de serviços públicos, de modo a assegurar que somente sejam utilizados os controles indispensáveis, de acordo com os limites de exposição a riscos institucionalmente definidos, e que sejam eliminados controles desnecessários ou economicamente desvantajosos
- ☐ g) a organização utiliza os resultados das pesquisas de satisfação como subsídio para promover melhoria na prestação dos serviços

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Gestão de riscos; Meta; Serviços públicos prestados em meio digital; Usuário.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência das metas de simplificação, como: plano ou estratégia de transformação digital com metas definidas; indicadores e metas para digitalização de serviços; metas de redução de atendimento presencial ou de exigências documentais; iniciativas de interoperabilidade e integração; relatórios de acompanhamento; resultados de pesquisas de satisfação utilizados para melhorias; ou outras evidências cabíveis.

Gestão de Tecnologia da Informação

Esta seção avalia se a organização possui processos estruturados para planejar, executar, acompanhar e melhorar a gestão da tecnologia da informação. Enquanto a governança de TI está relacionada ao direcionamento e à supervisão pela alta administração, a gestão de TI trata da execução das atividades necessárias para entregar serviços, sistemas e soluções de tecnologia de forma segura, eficiente e alinhada às necessidades institucionais.

Nesse contexto, espera-se que a organização realize o planejamento de TI, mantenha plano vigente, organize seus serviços, monitore níveis de atendimento, controle mudanças, gerencie ativos e configurações, trate incidentes, avalie riscos e assegure a continuidade dos serviços críticos. Essas práticas contribuem para reduzir falhas, evitar interrupções, melhorar a qualidade dos serviços e apoiar o funcionamento das áreas finalísticas e administrativas.

A gestão de TI também envolve a adoção de processos para desenvolver, adquirir, manter e sustentar soluções tecnológicas, com participação das áreas usuárias, consideração de requisitos de segurança, acessibilidade, usabilidade e qualidade, além do acompanhamento de projetos, prazos, custos, riscos e resultados.

Uma gestão de TI efetiva fortalece a capacidade da organização de atender às demandas internas e externas, apoiar a transformação digital, proteger informações, melhorar a prestação dos serviços públicos e utilizar os recursos tecnológicos de forma planejada, controlada e transparente.

Planejamento de Tecnologia da Informação

2101. A organização executa processo de planejamento de tecnologia da informação.

O processo de planejamento de TI é o conjunto de atividades formais para definir, priorizar e revisar iniciativas de TI, alinhadas às necessidades institucionais e com participação das áreas envolvidas.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) as áreas demandantes de soluções de TI participam do processo de planejamento de tecnologia da informação
- ☐ b) a organização estabeleceu critérios para orientar a seleção e a priorização das iniciativas de TI (projetos e ações) e os mantém atualizados
- ☐ c) as análises de benefícios, de custos e de riscos subsidiam as decisões relacionadas à seleção e à priorização das iniciativas de TI (projetos e ações)
- ☐ d) o processo de planejamento de TI está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Planejamento de Tecnologia da Informação; Risco; TI (Tecnologia da Informação).



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do processo de planejamento de TI, como: norma ou procedimento formal que discipline o planejamento; plano de TI vigente (ex.: PEDTIC/PDTI/PEI de TI); registros de participação das áreas demandantes; critérios de priorização documentados; estudos de custo, benefício e risco; atas de reuniões de planejamento; evidências de integração com planejamento institucional; relatórios de avaliação e revisão do processo; ou outras evidências cabíveis.

2102. A organização possui plano de tecnologia da informação vigente.

O plano de TI é o documento que consolida objetivos, iniciativas e ações de tecnologia, alinhado à estratégia institucional e utilizado para orientar investimentos, contratações e execução da TI.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o plano de tecnologia da informação (plano de TI) é aprovado pelo dirigente máximo da organização ou por dirigente ou colegiado que integra a alta administração
- ☐ b) o plano de TI é publicado na internet, para fácil acesso de partes interessadas e da sociedade
- ☐ c) o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações
- ☐ d) as iniciativas de TI (projetos e ações) constantes do plano de TI alinham-se aos objetivos e iniciativas definidos no planejamento institucional (como PPA, planos estratégicos, planos setoriais e plano de governo, no caso de municípios), bem como, quando aplicável, às estratégias e diretrizes estabelecidas por instâncias superiores de governança (como a Estratégia Nacional de Tecnologia da Informação e Comunicação do Poder Judiciário - ENTIC-JUD, normas e orientações do SETIC/PRODERJ (para órgãos estaduais) ou instâncias de governança equivalentes no âmbito municipal)
- ☐ e) é feito acompanhamento concomitante à execução do plano de TI, com vistas a assegurar sua observância e possibilitar a realização de ajustes que se fizerem necessário

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Dirigente máximo; Estratégia; Partes interessadas; Planejamento de Tecnologia da Informação; Plano de Tecnologia da Informação; TI (Tecnologia da Informação).



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do plano de TI, como: documento vigente aprovado pela alta administração; publicação do plano (se aplicável); vinculação com orçamento e plano de contratações; alinhamento com planejamento institucional; relatórios ou atas de acompanhamento da execução; indicadores e revisões do plano; ou outras evidências cabíveis, indicando a abrangência na organização.

Gestão de Serviços de Tecnologia da Informação

2201. A organização elabora um catálogo de serviços de tecnologia da informação e monitora níveis de serviço.

O catálogo de serviços de TI descreve os serviços prestados, seus níveis de atendimento e responsáveis, permitindo acordar, monitorar e melhorar a qualidade dos serviços oferecidos aos usuários.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes)
- ☐ b) o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização
- ☐ c) o catálogo é de fácil acesso e está amplamente disponível a seus usuários e às equipes de suporte
- ☐ d) são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes
- ☐ e) a área de gestão de tecnologia da informação monitora continuamente o alcance dos níveis de serviço estabelecidos nos ANS

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Acordo de Nível de Serviço (ANS); Área de gestão de tecnologia da informação; Catálogo de serviços de TI; Gestão de serviços de tecnologia da informação; Meta; Serviços de tecnologia da informação; TI (Tecnologia da Informação); Usuário.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do catálogo e da gestão de níveis de serviço, como: catálogo de serviços vigente (ex.: portal, documento ou sistema); ANS firmados com secretarias/áreas usuárias; definição de metas (prazos, disponibilidade, suporte); registros de monitoramento dos níveis de serviço; relatórios de desempenho; canais de atendimento definidos; ou outras evidências cabíveis, indicando a abrangência na organização.

2202. A organização executa processo de gestão de mudanças.

A gestão de mudanças é o processo de planejar, avaliar, aprovar, implementar e monitorar alterações em serviços e sistemas de TI, reduzindo riscos e impactos aos usuários.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização estabeleceu critérios para orientar a aprovação de mudanças, inclusive quanto ao tratamento de casos de exceção (mudanças emergenciais)
- ☐ b) mudanças são previamente comunicadas a todas as partes que possam ser afetadas
- ☐ c) identificam-se os serviços e ativos de TI que possam ser afetados pela mudança, de modo a avaliar impactos em níveis de serviços acordados
- ☐ d) a realização de cada mudança é precedida de planejamento e testes
- ☐ e) mudanças executadas são rastreáveis e monitoradas, com vistas à avaliação de sua efetividade e para permitir ações corretivas, no caso de ocorrência de efeitos não identificados nas fases de planejamento e testes
- ☐ f) o processo de gestão de mudanças está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Efetividade; Prática de habilitação de mudança.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do processo de gestão de mudanças, como: norma ou procedimento formal; registros de solicitações e aprovações de mudanças (incluindo emergenciais); planos e evidências de testes; comunicações às áreas impactadas; registros de impactos e serviços afetados; logs ou sistemas de rastreabilidade; relatórios de avaliação pós-implementação; ou outras evidências cabíveis, indicando a abrangência na organização.

2203. A organização executa processo de gestão de configuração e ativos (de serviços de tecnologia da informação).

A gestão de configuração e ativos é o controle dos recursos de TI e suas relações, garantindo informações confiáveis para operação, mudanças e tomada de decisão.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles
- ☐ b) a base de dados de configurações é utilizada como insumo para o planejamento e o acompanhamento das mudanças
- ☐ c) o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Gestão de serviços de tecnologia da informação; Prática de gerenciamento de configuração e ativos; Serviços de tecnologia da informação; TI (Tecnologia da Informação).



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência da gestão de configuração e ativos, como: inventário atualizado de ativos e serviços de TI; base de dados de configuração (CMDB ou equivalente); registros de relacionamento entre sistemas, infraestrutura e serviços; uso dessas informações em mudanças; norma ou procedimento formal; relatórios ou ferramentas de controle; ou outras evidências cabíveis, indicando a abrangência na organização.

2204. A organização executa processo(s) de gestão de incidentes de serviços de tecnologia da informação e de incidentes de segurança da informação.

A gestão de incidentes trata da identificação, registro, priorização e resolução de falhas em serviços e segurança da informação, visando restabelecer rapidamente o serviço e reduzir impactos.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
- ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
↳ Indique que leis e/ou normas são essas:
- ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
↳ Identifique esses estudos:
- ☐ Não se aplica por outras razões.
↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização definiu regras para a priorização e o escalamento de incidentes
- ☐ b) a resolução de incidentes considera os níveis de serviços especificados em acordos com as áreas clientes
- ☐ c) há base(s) de conhecimento que registra(m) erros conhecidos e problemas, de modo a tornar eficiente e efetiva a resolução de incidentes
- ☐ d) o(s) processo(s) de gestão de incidentes está(ão) formalizado(s) (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
- ☐ e) a organização definiu procedimentos e responsabilidades quanto à notificação e ao tratamento das notificações de incidentes de segurança da informação, bem como quanto à adoção de ações emergenciais, diretrizes para escalamento e comunicação interna e externa
- ☐ f) a organização definiu procedimentos e responsabilidades quanto à análise dos incidentes, identificação de causas raízes e planejamento e implementação de ações corretivas

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Acordo de Nível de Serviço (ANS); Gestão de serviços de tecnologia da informação; Prática de gestão de incidentes; Segurança da Informação; Serviços de tecnologia da informação; TI (Tecnologia da Informação).



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência da gestão de incidentes, como: norma ou procedimento formal; registros de incidentes (chamados/tickets); critérios de priorização e escalonamento; base de conhecimento com erros conhecidos; relatórios de atendimento e tempos de resolução; evidências de tratamento de incidentes de segurança (notificação, resposta e comunicação); análise de causa raiz e ações corretivas; ou outras evidências cabíveis, indicando a abrangência na organização.

Gestão de Riscos de TI e Segurança da Informação

2301. A organização executa processo de gestão dos riscos de tecnologia da informação relativos a processos de negócio.

A gestão de riscos de TI é o processo de identificar, avaliar e tratar riscos que possam afetar sistemas, serviços e processos de negócio, reduzindo impactos e apoiando decisões.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização identifica e avalia os riscos associados com o uso de Tecnologia da Informação nos processos organizacionais críticos para o negócio (Riscos de TI)
- ☐ b) a organização trata os Riscos de TI com base em um plano de tratamento de risco
- ☐ c) o processo de gestão dos riscos de tecnologia da informação está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Avaliação de riscos; Critérios de análise e avaliação de riscos; Fonte de risco; Gestão de riscos; Identificação de riscos; Limites de exposição ao risco; Mitigar risco; Processo de gestão de riscos; Resposta a risco; Risco de Tecnologia da Informação; TI (Tecnologia da Informação); Tratamento de risco.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência da gestão de riscos de TI, como: matriz de riscos de TI vinculada a processos de negócio; critérios de avaliação e priorização; planos de tratamento; relatórios de acompanhamento; registros de revisão periódica; norma ou procedimento formal; evidências de integração com riscos institucionais; ou outras evidências cabíveis, indicando a abrangência na organização.

2302. A organização executa processo de gestão de riscos de segurança da informação.

A gestão de riscos de segurança da informação identifica, avalia e trata ameaças à confidencialidade, integridade e disponibilidade das informações e dos serviços.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização identifica e avalia riscos de segurança da informação
- ☐ b) a organização trata riscos de segurança da informação com base em um plano de tratamento de riscos
- ☐ c) a organização possui um gestor formalmente responsável por coordenar a gestão de riscos de segurança da informação
- ☐ d) o processo de gestão de riscos de segurança da informação está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Avaliação de riscos; Critérios de análise e avaliação de riscos; Fonte de risco; Gestão de riscos; Identificação de riscos; Limites de exposição ao risco; Mitigar risco; Processo de gestão de riscos; Resposta a risco; Risco de Segurança da Informação; Segurança da Informação; Tratamento de risco.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência da gestão de riscos de segurança da informação, como: matriz ou inventário de riscos; registros de identificação e avaliação (impacto e probabilidade); planos de tratamento com responsáveis e prazos; designação formal de responsável; norma ou procedimento institucional; relatórios de acompanhamento; ou outras evidências cabíveis, indicando a abrangência na organização.

2303. A organização executa processo de gestão de continuidade de serviços de tecnologia da informação.

A gestão de continuidade de TI garante que serviços e sistemas críticos possam ser mantidos ou recuperados em caso de falhas, desastres ou interrupções.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização elabora um plano de continuidade de serviços de TI
- ☐ b) as ações e os prazos definidos no plano de continuidade de serviços de TI fundamentam-se em análises de impacto no negócio (AIN/BIA) realizadas sobre os processos organizacionais críticos
- ☐ c) o plano de continuidade de serviços de TI é testado e revisado periodicamente
- ☐ d) o processo de gestão de continuidade de serviços de TI está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: **Análise de impacto no negócio; Gestão de continuidade do negócio; Plano de continuidade do negócio; Serviços de tecnologia da informação; TI (Tecnologia da Informação).**



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência da continuidade de serviços de TI, como: plano de continuidade ou de recuperação de desastres (PCN/DRP); análises de impacto no negócio (BIA/AIN); definição de prazos de recuperação (RTO/RPO); registros de testes e revisões do plano; norma ou procedimento formal; relatórios de incidentes relevantes; ou outras evidências cabíveis, indicando a abrangência na organização.

Estrutura de Segurança da Informação

2401. A organização dispõe de uma política de segurança da informação.

A política de segurança da informação define diretrizes e responsabilidades para proteger dados e sistemas, assegurando confidencialidade, integridade e disponibilidade das informações.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a política declara o comprometimento da alta administração e estabelece princípios, diretrizes, objetivos, estruturas e responsabilidades relativos à segurança da informação
- ☐ b) a política (ou norma interna complementar) contempla diretrizes sobre gestão de riscos de segurança da informação
- ☐ c) a política abrange diretrizes para conscientização, treinamento e educação em segurança da informação
- ☐ d) a política é amplamente comunicada a empregados, servidores, colaboradores e partes externas relevantes
- ☐ e) a política é mantida atualizada, por meio de revisões periódicas

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Colaboradores; Diretriz; Gestão de riscos; Informação; Política; Política de segurança da informação; Risco de Segurança da Informação; Segurança da Informação.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência da política de segurança da informação, como: documento formal aprovado pela alta administração; conteúdo com diretrizes, responsabilidades e gestão de riscos; registros de comunicação e divulgação; ações de conscientização e treinamento; histórico de revisões; ou outras evidências cabíveis, indicando a abrangência na organização.

2402. A organização dispõe de comitê de segurança da informação.

O comitê de segurança da informação é a instância que coordena decisões, diretrizes e ações para proteger dados e sistemas, envolvendo áreas relevantes da organização.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o comitê de segurança da informação realiza as atividades previstas em seu ato constitutivo
- ☐ b) o comitê formula diretrizes para a segurança da informação
- ☐ c) o comitê propõe a elaboração e a revisão de normas e de procedimentos inerentes à segurança da informação
- ☐ d) o comitê é composto por representantes de áreas relevantes da organização

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Comitê de segurança da informação; Segurança da Informação.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do comitê de segurança da informação, como: ato de criação com competências definidas; composição com representantes de áreas relevantes; atas de reuniões; deliberações sobre diretrizes, normas e ações de segurança; registros de acompanhamento de decisões; ou outras evidências cabíveis, indicando a abrangência na organização.

2403. A organização possui um gestor institucional de segurança da informação.

O gestor de segurança da informação é o responsável por coordenar políticas, riscos e ações de proteção de dados e sistemas, com autoridade definida pela alta administração.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o gestor institucional de segurança da informação foi designado formalmente pela alta administração
- ☐ b) o gestor institucional de segurança da informação reporta-se diretamente à alta administração
- ☐ c) o gestor institucional de segurança da informação coordena o processo de gestão de riscos de segurança da informação em âmbito institucional
- ☐ d) o gestor institucional de segurança da informação coordena ações de segurança da informação em âmbito institucional
- ☐ e) o gestor institucional de segurança da informação fomenta e coordena ações periódicas de conscientização e de treinamento em segurança da informação para todas as partes interessadas, incluindo autoridades, servidores e colaboradores
- ☐ f) o gestor institucional de segurança da informação detém as prerrogativas e os recursos necessários para o desempenho de todas as suas competências

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Competências; Gestão de riscos; Gestor institucional de segurança da informação; Informação; Partes interessadas; Risco de Segurança da Informação; Segurança da Informação.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do gestor de segurança da informação, como: ato formal de designação; descrição de atribuições e vínculo com a alta administração; registros de atuação na coordenação de riscos e ações de segurança; evidências de campanhas de conscientização e treinamentos; estrutura ou recursos disponíveis; ou outras evidências cabíveis, indicando a abrangência na organização.

2404. A organização possui um responsável pelo tratamento e resposta a incidentes.

O responsável por incidentes coordena a detecção, análise e resposta a eventos de segurança, reduzindo impactos e restabelecendo serviços com rapidez.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o responsável ou equipe (ex.: ETIR) foi designado formalmente pela alta administração
- ☐ b) o responsável ou equipe (ex.: ETIR) detecta, registra e analisa incidentes de segurança da informação
- ☐ c) o responsável ou equipe (ex.: ETIR) utiliza informações sobre vulnerabilidades para apoiar a prevenção e resposta a incidentes
- ☐ d) o responsável ou equipe (ex.: ETIR) recebe e trata notificações relacionadas a incidentes de segurança da informação
- ☐ e) o responsável ou equipe (ex.: ETIR) coordena e executa atividades de tratamento e resposta a eventos de segurança da informação
- ☐ f) o responsável ou equipe (ex.: ETIR) realiza a comunicação de incidentes às partes interessadas internas e externas, conforme critérios definidos
- ☐ g) o responsável ou equipe (ex.: ETIR) realiza análise pós-incidente para identificar causas e propor melhorias

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Competências; Gestão de riscos; Responsável pelo tratamento e resposta a incidentes; Informação; Partes interessadas; Risco de Segurança da Informação; Segurança da Informação.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do responsável por incidentes, como: ato formal de designação; descrição de competências; evidências da atuação de equipe de resposta a incidentes (ex.: ETIR); registros de monitoramento e análise de eventos; relatórios de incidentes tratados; registros de vulnerabilidades identificadas; comunicações e respostas a incidentes; evidências de coordenação das ações de resposta; ou outras evidências cabíveis, indicando a abrangência na organização.

Processos de Segurança da Informação

2501. A organização executa processo de gestão de ativos associados à informação.

A gestão de ativos associados à informação consiste em identificar, inventariar, classificar e acompanhar ativos que armazenam, processam ou transmitem informações, assegurando sua proteção durante todo o ciclo de vida. Exemplos: sistema de prontuário eletrônico da saúde, sistema de arrecadação tributária, folha de pagamento, portal do aluno, backups, banco de dados de cidadãos, servidores, notebooks e documentos digitais que contenham informações críticas ou dados pessoais.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização mantém um inventário dos ativos associados à informação
- ☐ b) a organização definiu responsabilidades pelos ativos associados à informação
- ☐ c) o inventário identifica as informações críticas que os ativos armazenam, processam ou transmitem
- ☐ d) o processo de gestão de ativos associados à informação subsidia a implantação de controles e ações com vistas a assegurar a adequada proteção dos ativos e das informações que armazenam, processam ou transmitem
- ☐ e) o processo de gestão de ativos associados à informação subsidia a implantação de ações mitigatórias aplicáveis no caso de ocorrência de evento catastrófico que inviabilize a utilização de ativos
- ☐ f) o processo de gestão de ativos associados à informação está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Ativos associados à informação; Gestão do desempenho; Informação; Processo de gestão de ativos.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência da gestão de ativos associados à informação, como: inventário de ativos e informações críticas; definição formal de responsáveis pelos ativos; classificação ou identificação de informações sensíveis ou críticas; registros de controles de proteção aplicados; planos ou ações mitigatórias para indisponibilidade de ativos críticos; norma ou procedimento formal; relatórios de acompanhamento ou revisão do processo; ou outras evidências cabíveis, indicando a abrangência na organização.

2502. A organização executa processo de controle de acesso à informação e aos ativos associados à informação.

O controle de acesso consiste em definir, conceder, revisar e revogar acessos físicos e lógicos à informação e aos ativos associados, assegurando que apenas usuários autorizados tenham acesso adequado às informações e serviços.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização implementa controles de acesso físicos e lógicos à informação e aos ativos associados à informação que são por ela gerenciados ou custodiados, com vistas a proteger adequadamente a confidencialidade das informações não públicas e a integridade e a disponibilidade das informações consideradas críticas para o negócio
- ☐ b) os controles de acesso implementados na organização aplicam o princípio “necessidade de conhecer”, o qual prescreve que deve haver necessidade legítima que justifique o acesso à informação por pessoa, sistema ou entidade, bem como o princípio “privilegio mínimo”, o qual estabelece que o perfil de acesso concedido deve incluir tão somente os poderes necessários para o atendimento das legítimas necessidades
- ☐ c) há controles de acesso lógicos na organização que utilizam autenticação com certificado digital ICP-Brasil, a fim de prover identificação inequívoca de pessoas físicas e jurídicas e comprovação de autoria em transações digitais
- ☐ d) a organização analisa criticamente, a intervalos regulares, os direitos de acesso lógicos e físicos existentes, com vistas à remoção de direitos que deixaram de ser necessários e para assegurar que privilégios indevidos não foram obtidos
- ☐ e) a organização instituiu uma Política de Controle de Acesso (PCA), a qual estabelece princípios, objetivos, diretrizes, principais atividades e responsabilidades relativos ao processo de controle de acesso

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Ativos associados à informação; Certificado digital; Controle; Diretriz; Gestão do desempenho; Informação; Política; Serviço de TI.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do processo de controle de acesso, como: Política de Controle de Acesso (PCA); normas ou procedimentos de concessão, revisão e revogação de acessos; perfis e matrizes de acesso; registros de revisões periódicas de privilégios; evidências de autenticação forte ou uso de certificado digital; logs de acesso; relatórios de monitoramento; ou outras evidências cabíveis, indicando a abrangência na organização.

2503. A organização executa processo para classificação e tratamento de informações.

A classificação e tratamento de informações consiste em identificar informações conforme sua criticidade, sensibilidade ou sigilo e aplicar medidas adequadas de proteção, armazenamento, acesso e compartilhamento, de acordo com requisitos legais e de negócio.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) informações pessoais são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção
- ☐ b) a organização informa em seu sítio eletrônico as hipóteses em que, no exercício de suas competências, realiza o tratamento de dados pessoais, bem como fornece informações claras e atualizadas sobre a previsão legal, a finalidade, os procedimentos e as práticas de tratamento que utiliza
- ☐ c) informações sigilosas em razão de sua imprescindibilidade à segurança da sociedade ou do Estado são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção
- ☐ d) informações sigilosas em função de outras hipóteses legais de sigilo ou segredo são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção
- ☐ e) informações críticas para a organização em razão de necessidades do negócio (p. ex. requisitos associados à integridade, disponibilidade, autenticidade ou a outros atributos da informação) são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção
- ☐ f) o processo de classificação e tratamento de informações está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Competências; Processo para classificação e tratamento de informações; Tratamento de dados pessoais.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do processo de classificação e tratamento de informações, como: política ou norma de classificação da informação; critérios de classificação e rotulagem; inventários ou registros de informações críticas, pessoais ou sigilosas; procedimentos de tratamento e proteção; controles de acesso e armazenamento; evidências de adequação à LGPD e à LAI; registros de revisão periódica; ou outras evidências cabíveis, indicando a abrangência na organização.

2504. A organização executa atividades de gestão da segurança dos recursos de processamento da informação, inclusive dos recursos de computação em nuvem.

A gestão da segurança dos recursos de processamento da informação consiste em proteger dispositivos, sistemas, redes, aplicações e ambientes de TI contra acessos indevidos, falhas, vulnerabilidades e ameaças cibernéticas, incluindo ambientes locais, terceirizados e em nuvem.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização gerencia (inventaria e controla) os dispositivos conectados em sua rede
- ☐ b) a organização gerencia (inventaria e controla) os softwares instalados nos dispositivos conectados em sua rede
- ☐ c) a organização gerencia vulnerabilidades técnicas em seus ativos de software, de hardware e de rede críticos para o negócio
- ☐ d) a organização implementa configurações seguras em seus ativos de software, de hardware e de rede críticos para o negócio
- ☐ e) a organização mantém, monitora e analisa logs de auditoria dos ativos de software, de hardware e de rede críticos para o negócio
- ☐ f) a organização aplica controles compensatórios para o uso de privilégios administrativos em seus ativos de software, de hardware e de rede críticos para o negócio
- ☐ g) a organização implementa defesas contra malware (ex: vírus) e outras ameaças cibernéticas (ex: phishing)
- ☐ h) a organização limita e controla o uso de portas, protocolos e serviços de rede nas conexões de sua rede interna com a internet e outras redes externas
- ☐ i) a organização implementa defesa de perímetro das conexões de sua rede interna com a internet e outras redes externas
- ☐ j) a organização implementa cópias regulares de segurança (backup) das informações em meio digital, conforme as melhores práticas e as necessidades de negócio, incluindo a realização periódica de testes de recuperação das informações
- ☐ k) a organização executa regularmente testes de segurança em seu ambiente de TI (detecção de vulnerabilidades e testes de penetração)

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Gestão do desempenho; Informação; Processo para classificação e tratamento de informações.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência da gestão da segurança dos recursos de processamento da informação, como: inventário de dispositivos e softwares; registros de gestão de vulnerabilidades e aplicação de correções; padrões de configuração segura; logs e relatórios de monitoramento; controles de privilégios administrativos; evidências de antivírus, firewall e proteção contra malware; políticas e registros de backup e testes de recuperação; relatórios de testes de segurança; ou outras evidências cabíveis, indicando a abrangência na organização.

2505. A organização realiza periodicamente ações de treinamento e/ou capacitação em segurança da informação.

As ações de treinamento, capacitação e conscientização em segurança da informação buscam orientar servidores, colaboradores e usuários sobre riscos, boas práticas e responsabilidades relacionadas à proteção das informações e dos recursos de TI.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização realiza ações de capacitação voltadas para segurança da informação
- ☐ b) a organização participa de ações de capacitação voltadas para segurança da informação
- ☐ c) a organização realiza ações de conscientização em segurança de TIC
- ☐ d) a organização possui programa permanente de conscientização em segurança da informação

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Informação; Plano de capacitação (Plano de Treinamento); Segurança da Informação.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência das ações de treinamento e conscientização em segurança da informação, como: plano ou programa de capacitação; registros de treinamentos realizados; campanhas de conscientização; materiais educativos; listas de presença; certificados; comunicações internas; cronogramas periódicos; ou outras evidências cabíveis, indicando a abrangência na organização.

Gestão de Soluções e Projetos de TI

2601. A organização executa um processo de software.

O processo de software consiste em definir e executar atividades para desenvolvimento, manutenção, sustentação ou aquisição de sistemas, incluindo requisitos de negócio, segurança, acessibilidade, qualidade e responsabilidades ao longo do ciclo de vida do software.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o processo de software utilizado pela organização promove a participação de representante da área de negócio como integrante da equipe de desenvolvimento ou aquisição de software, desde sua concepção até a aceitação final
- ☐ b) o processo de software da organização promove a identificação precoce de requisitos de segurança da informação e a gestão permanente desses requisitos durante todo o ciclo de vida do software
- ☐ c) o processo de software da organização promove a identificação precoce de requisitos de acessibilidade e de usabilidade, bem como a gestão permanente desses requisitos durante todo o ciclo de vida do software
- ☐ d) a organização assegura os seus direitos autorais, de propriedade e de uso relativamente ao software que desenvolve por meio de contratação
- ☐ e) organização avalia, por meio de mensurações, indicadores e metas, a qualidade do software desenvolvido ou adquirido
- ☐ f) o processo de software está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: **Área de negócio; Processo de software; Segurança da Informação.**



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do processo de software, como: norma ou metodologia de desenvolvimento/aquisição; documentos de requisitos; participação das áreas de negócio; registros de testes e validações; critérios de segurança, acessibilidade e usabilidade; indicadores de qualidade; contratos com cláusulas de propriedade intelectual; fluxos ou ferramentas de desenvolvimento; ou outras evidências cabíveis, indicando a abrangência na organização.

2602. A organização executa processo de gestão de projetos de tecnologia da informação.

A gestão de projetos de TI consiste em planejar, executar, acompanhar e controlar projetos de tecnologia da informação, assegurando o gerenciamento de escopo, prazo, custos, recursos, riscos e resultados.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização possui base de dados consolidada (portfólio) de projetos de tecnologia da informação
- ☐ b) escopo, custos, uso de recursos e cumprimento de prazos são gerenciados em cada projeto
- ☐ c) é realizada a gestão de riscos de cada um dos projetos de alta materialidade ou alta relevância
- ☐ d) o processo de gestão de projetos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Gestão de riscos; Política; Projeto; TI (Tecnologia da Informação).



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência da gestão de projetos de TI, como: portfólio de projetos; planos de projeto; cronogramas; registros de acompanhamento de escopo, custos e prazos; análises e planos de tratamento de riscos; relatórios de status; metodologia ou norma formal de gestão de projetos; indicadores de desempenho; ou outras evidências cabíveis, indicando a abrangência na organização.

Gestão de Pessoas em Tecnologia da Informação

2701. Os perfis profissionais desejados para cada ocupação ou grupo de ocupações de gestão de tecnologia da informação estão definidos e documentados.

Os perfis profissionais de gestão definem as responsabilidades, atribuições, competências e habilidades esperadas dos ocupantes de cargos de liderança e gestão, promovendo transparência, clareza de papéis e melhor seleção de gestores.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) as responsabilidades e atribuições dos gestores da área de tecnologia da informação estão definidas, documentadas e publicadas
- ☐ b) as responsabilidades e atribuições dos gestores da área de tecnologia da informação são revisadas periodicamente e publicadas
- ☐ c) relacionou-se, no perfil profissional, além de requerimentos de ordem legal, um conjunto de competências e habilidades que os ocupantes dos cargos de gestão devem possuir
- ☐ d) a organização utiliza mecanismos de transparência ativa para disponibilizar às partes interessadas internas e externas os perfis profissionais definidos para as ocupações de gestão

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Competências; Gestor; Ocupação; Partes interessadas; Perfil profissional; Perfil profissional desejado; Planejamento da força de trabalho; Transparência; Transparência ativa.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência dos perfis profissionais de gestão, como: normativos ou documentos com atribuições e competências; descrições de cargos ou funções; matrizes de competências; registros de revisão periódica; publicações em portal institucional ou transparência ativa; atos de designação; ou outras evidências cabíveis, indicando a abrangência na organização.

2702. Os perfis profissionais desejados para cada ocupação ou grupo de colaboradores da área de gestão de tecnologia da informação estão definidos e documentados.

Os perfis profissionais da área de TI definem responsabilidades, atribuições, competências e habilidades esperadas dos colaboradores que atuam em tecnologia da informação, apoiando a organização, a capacitação e a gestão da força de trabalho de TI.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) as responsabilidades e atribuições das ocupações ou grupo de ocupações da área de tecnologia da informação estão definidas, documentadas e publicadas
- ☐ b) as responsabilidades e atribuições das ocupações ou grupo de ocupações da área de tecnologia da informação são revisadas periodicamente e publicadas
- ☐ c) relacionou-se, no perfil profissional, além de requerimentos de ordem legal, um conjunto de competências e habilidades que os ocupantes dos cargos devem possuir
- ☐ d) a organização utiliza mecanismos de transparência ativa para disponibilizar às partes interessadas internas e externas os perfis profissionais definidos

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Área finalística; Colaboradores; Competências; Ocupação; Partes interessadas; Perfil profissional; Perfil profissional desejado; Transparência; Transparência ativa; Transparência passiva.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência dos perfis profissionais da área de TI, como: descrições de cargos ou funções; matrizes de competências; normativos com atribuições e responsabilidades; registros de revisão periódica; publicações em portal institucional ou mecanismos de transparência; planos de capacitação relacionados; ou outras evidências cabíveis, indicando a abrangência na organização.

2703. Há definição do quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação.

A definição do quantitativo necessário de pessoal de TI consiste em estimar, de forma planejada e documentada, a quantidade de profissionais necessária para executar atividades de tecnologia da informação e segurança da informação na organização.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) há política de orientação para o dimensionamento da força de trabalho
- ☐ b) definiu-se o quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação com base em critério(s) ou procedimento(s) técnico(s)
- ☐ c) definiu-se, de maneira documentada, um quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação
- ☐ d) há revisão periódica do quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Área finalística; Planejamento da força de trabalho; Política; Procedimento técnico; Quantitativo necessário; Unidade organizacional.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do dimensionamento da força de trabalho de TI, como: política ou metodologia de dimensionamento; estudos ou relatórios técnicos; definição documentada do quantitativo necessário; critérios utilizados (serviços, sistemas, demanda, riscos ou complexidade); revisões periódicas; planos de provimento; ou outras evidências cabíveis, indicando a abrangência na organização.

2704. A escolha dos gestores de tecnologia da informação e segurança da informação ocorre segundo perfis profissionais previamente definidos e documentados.

A escolha de gestores de TI e segurança da informação com base em perfis profissionais consiste em utilizar critérios previamente definidos de competências, experiência, integridade e habilidades para ocupação de cargos e funções de gestão.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) avalia-se, previamente à nomeação/designação, se o gestor possui impedimentos legais decorrentes de sanções administrativas, cíveis, eleitorais ou penais, incluindo envolvimento em atos de corrupção
- ☐ b) os gestores são selecionados com base em perfil profissional previamente definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado
- ☐ c) são utilizadas ferramentas estruturadas para auxiliar a seleção dos ocupantes dos cargos/funções comissionados de gestão
- ☐ d) são utilizados mecanismos de transparência ativa para disponibilizar às partes interessadas externas e internas o currículo dos ocupantes dos cargos/funções de gestão

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Gestor; Indicador; Perfil profissional; Perfil profissional desejado; Planejamento da força de trabalho.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do processo de escolha de gestores de TI e segurança da informação, como: perfis profissionais documentados; critérios de seleção; registros de avaliação prévia de impedimentos legais; utilização de entrevistas, análises curriculares ou outras ferramentas estruturadas; currículos publicados; atos de designação; ou outras evidências cabíveis, indicando a abrangência na organização.

2705. As lacunas de competências dos colaboradores e gestores da área de tecnologia da informação e de segurança da informação são identificadas e documentadas.

A identificação de lacunas de competências consiste em avaliar e registrar conhecimentos, habilidades e capacidades que precisam ser desenvolvidos pelos colaboradores e gestores de TI e segurança da informação para atender às necessidades da organização.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) as lacunas de competências pessoais (transversais, comuns a todos os colaboradores) da organização são identificadas e documentadas
- ☐ b) as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas
- ☐ c) as lacunas de competências técnicas da área de tecnologia da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas
- ☐ d) as lacunas de competências técnicas da área de segurança da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Área finalística; Colaboradores; Competências; Gestão; Gestor; Lacuna de competência ou de perfil profissional.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência da identificação de lacunas de competências, como: matrizes de competências; avaliações de perfil; levantamentos de necessidades de capacitação; diagnósticos de competências técnicas e gerenciais; planos de desenvolvimento; relatórios ou registros documentados; ou outras evidências cabíveis, indicando a abrangência na organização.

2706. As lacunas de competências dos colaboradores e gestores da área de tecnologia da informação e de segurança da informação da organização são tratadas.

O tratamento de lacunas de competências consiste em executar ações para desenvolver conhecimentos, habilidades e capacidades necessárias aos colaboradores e gestores de TI e segurança da informação, de acordo com as necessidades da organização.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização elabora plano de capacitação (plano de treinamento) visando o tratamento das lacunas de competência identificadas
- ☐ b) a organização incentiva seus colaboradores e gestores a participar das ações de capacitação existentes
- ☐ c) a organização monitora a participação dos colaboradores e gestores nas ações de capacitação existentes
- ☐ d) a organização analisa periódica e criticamente o plano de capacitação (plano de treinamento) existente

? Considere se a organização executa ações para tratar lacunas de competências, como capacitação, realocação, recrutamento, contratação ou apoio especializado.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do tratamento de lacunas de competências, como: plano de capacitação ou treinamento; registros de participação em cursos e treinamentos; ações de incentivo à capacitação; acompanhamento de participação e resultados; revisões periódicas do plano de capacitação; contratações ou apoio especializado; ou outras evidências cabíveis, indicando a abrangência na organização.

2707. A organização realiza, formalmente, avaliação de desempenho individual do pessoal de tecnologia da informação e de segurança da informação, com atribuição de nota ou conceito, tendo como critério de avaliação o alcance das metas previstas.

A avaliação de desempenho do pessoal de TI e segurança da informação consiste em medir formalmente o desempenho de colaboradores e gestores, considerando metas, resultados, competências e responsabilidades relacionadas às atividades exercidas.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) há normativo que trata da avaliação de desempenho dos colaboradores e gestores
- ☐ b) a avaliação abrange o desempenho dos gestores da área de tecnologia da informação
- ☐ c) a avaliação abrange o desempenho dos gestores da área de segurança da informação
- ☐ d) a avaliação abrange o desempenho dos colaboradores da área de tecnologia da informação
- ☐ e) a avaliação abrange o desempenho dos colaboradores da área de segurança da informação

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Área finalística; Avaliação de desempenho; Colaboradores; Gestor.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência da avaliação de desempenho do pessoal de TI e segurança da informação, como: normativos ou procedimentos de avaliação; formulários ou sistemas utilizados; critérios e metas avaliadas; registros de avaliações realizadas; atribuição de notas ou conceitos; planos de melhoria decorrentes das avaliações; ou outras evidências cabíveis, indicando a abrangência na organização.

2708. A organização possui em sua estrutura cargos específicos em tecnologia da informação e segurança da informação.

Os cargos específicos de TI e segurança da informação são funções ou cargos formalmente previstos na estrutura organizacional para execução de atividades técnicas, gerenciais ou especializadas relacionadas à tecnologia e à proteção das informações.

	Sim	Não
a) a organização possui em sua estrutura cargos efetivos em tecnologia da informação	☐	☐
b) a organização possui em sua estrutura cargos ou funções formalmente atribuídas à área de tecnologia da informação	☐	☐
c) a organização possui em sua estrutura cargos efetivos em segurança da informação	☐	☐
d) a organização possui em sua estrutura cargos ou funções formalmente atribuídas à área de segurança da informação	☐	☐



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência da existência de cargos específicos de TI e segurança da informação, como: leis, decretos ou normativos de criação de cargos; organogramas; planos de cargos e carreiras; editais de concurso; descrição de atribuições; relação de cargos providos; ou outras evidências cabíveis, indicando a abrangência na organização.

Gestão de Contratações de Tecnologia da Informação

2801. Os processos de trabalho relativos às contratações de tecnologia da informação estão definidos.

Os processos de trabalho relativos às contratações de TI consistem na definição formal das etapas, responsabilidades, procedimentos, controles e documentos relacionados ao planejamento da contratação, à seleção de fornecedores e à gestão e fiscalização contratual. A padronização de artefatos contribui para uniformizar procedimentos, reduzir falhas e aumentar a conformidade das contratações.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o processo de trabalho para o planejamento das contratações de TI contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa
- ☐ b) são disponibilizados artefatos padronizados para a fase de planejamento das contratações de TI, como Documento de Formalização da Demanda (DFD), Estudo Técnico Preliminar (ETP), Termo de Referência (TR), Matriz de Riscos ou documentos equivalentes
- ☐ c) o processo de trabalho para a seleção de fornecedores contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa
- ☐ d) são disponibilizados artefatos padronizados para a fase de seleção de fornecedores, como minutas, checklists, modelos de edital, pareceres, critérios de julgamento ou documentos equivalentes
- ☐ e) o processo de trabalho para a gestão e fiscalização de contratos contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa
- ☐ f) são disponibilizados artefatos padronizados para a gestão e fiscalização de contratos de TI, como modelos de plano de fiscalização, termos de recebimento, relatórios de acompanhamento, registros de ocorrências, avaliações de desempenho contratual ou documentos equivalentes
- ☐ g) os processos de trabalho e os artefatos padronizados estão aderentes às normas legais e infralegais que regem as contratações públicas

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Área de gestão de contratações / área de contratações; Processo de trabalho para a gestão de contratos; Processo de trabalho para a seleção de fornecedores; Processo de trabalho para o planejamento de cada contratação.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência dos processos de trabalho e dos artefatos padronizados relativos às contratações de TI, como: manuais, fluxos, normas ou procedimentos internos; modelos padronizados de documentos; checklists; definição de papéis e responsabilidades; fluxogramas; instruções de trabalho; artefatos de planejamento da contratação; processos de fiscalização contratual; referências à Lei 14.133/2021 e normativos correlatos; ou outras evidências cabíveis, indicando a abrangência na organização.

2802. A organização executa processo de planejamento anual das contratações.

O planejamento anual das contratações consiste em consolidar e priorizar, de forma planejada e coordenada, as necessidades de contratação da organização para determinado exercício, considerando objetivos institucionais, orçamento e demandas das áreas envolvidas.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a alta administração (ou conselho ou colegiado superior) aprova formalmente o Plano de Contratações Anual (PCA)
- ☐ b) os setores relevantes da organização participam da elaboração do PCA
- ☐ c) na elaboração do PCA são considerados os demais instrumentos de planejamento da organização
- ☐ d) o PCA fundamenta a proposta orçamentária da organização
- ☐ e) a organização divulga o PCA e as eventuais alterações do plano no Portal Nacional de Compras Públicas (PNCP)

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Conselho ou Colegiado Superior / instância superior; Plano de Contratações.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do processo de planejamento anual das contratações, como: Plano de Contratações Anual (PCA); normativos ou procedimentos relacionados; registros de participação das áreas envolvidas; aprovação pela alta administração; integração com planejamento institucional e orçamento; publicação no PNCP; cronogramas; ou outras evidências cabíveis, indicando a abrangência na organização.

2803. A organização torna públicos os documentos relacionados com cada contratação de tecnologia da informação, contemplando as fases de planejamento, seleção do fornecedor e gestão contratual, excepcionados os casos de sigilo amparados pela legislação.

A transparência das contratações consiste em disponibilizar publicamente documentos e informações relacionados às fases de planejamento, seleção de fornecedores e gestão contratual, permitindo o acompanhamento, controle social e fiscalização das contratações públicas, ressalvadas hipóteses legais de sigilo.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↪ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↪ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↪ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o Estudo Técnico Preliminar (ETP) das contratações é publicado no Portal Nacional de Compras Públicas (PNCP)
- ☐ b) o Termo de Referência (TR) ou projeto básico das contratações é publicado no PNCP
- ☐ c) o edital de credenciamento e de pré-qualificação, o aviso de contratação direta e o edital de licitação e respectivos anexos são publicados no PNCP
- ☐ d) a ata de registro de preços, a ata de julgamento, contendo propostas e lances oferecidos (quando for o caso) são publicadas no PNCP
- ☐ e) o inteiro teor dos contratos, notas de empenho, aditivos e termos de prorrogação de contratos são publicados no PNCP
- ☐ f) os termos de recebimentos provisórios e definitivos são publicados no PNCP
- ☐ g) a análise realizada e justificativa dada para subsidiar a decisão de prorrogação contratual são publicadas no PNCP

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Portal Nacional de Compras Públicas; Transparência; Transparência ativa.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência da transparência das contratações, como: links ou registros de publicação no Portal Nacional de Compras Públicas (PNCP); publicações de ETP, TR, editais, atas, contratos, aditivos e documentos de gestão contratual; normativos internos sobre transparência; relatórios de publicação; ou outras evidências cabíveis, indicando a abrangência na organização.

2804. No fluxo de contratação e gestão de contratos de soluções de tecnologia da informação, a organização adota as seguintes práticas de governança e controle:

A governança nas contratações de TI exige que as aquisições estejam alinhadas ao planejamento, possuam viabilidade técnica atestada pela área especializada, sejam construídas por equipes multidisciplinares e fiscalizadas com segregação de funções, garantindo que o pagamento esteja vinculado a resultados.

	Sim	Não
a) as contratações de soluções de TI, independentemente de qual seja a área demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI	☐	☐
b) as contratações de TI executadas no exercício encontram-se previamente estabelecidas nos instrumentos de planejamento vigentes (PDTI/PEDTIC e PCA)	☐	☐
c) a fase de planejamento de cada contratação de TI é conduzida por uma Equipe de Planejamento da Contratação formalmente designada (composta, minimamente, por integrante requisitante e integrante técnico da área de TI)	☐	☐
d) os Termos de Referência (TR) ou Projetos Básicos preveem Níveis Mínimos de Serviço (NMS), vinculando o pagamento à efetiva entrega de resultados ou níveis de qualidade, evitando o mero pagamento por postos de trabalho ou horas trabalhadas	☐	☐
e) a fase de planejamento das contratações de TI inclui a análise expressa de requisitos de segurança da informação e de proteção de dados pessoais (adequação à LGPD)	☐	☐

Caso tenha assinalado que as contratações de soluções de TI são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI, forneça evidência de norma regulamentando esse processo e de um caso concreto.

Resposta: _____



2805. Nas contratações de bens e serviços de Tecnologia da Informação, a organização faz uso das Notas Técnicas elaboradas pelo TCE-RJ.

O uso das Notas Técnicas do TCE-RJ consiste em considerar orientações, recomendações e boas práticas elaboradas pelo Tribunal para apoiar o planejamento, a instrução, a contratação e a fiscalização de bens e serviços de tecnologia da informação.

	Sim	Não
a) a Nota Técnica TCE-RJ n. 06/2023	☐	☐
b) a Nota Técnica TCE-RJ n. 08/2024	☐	☐

? As Notas Técnicas do TCE-RJ estão disponíveis em <https://www.tcerj.tc.br/cadastro-publicacoes/public/nota-tecnica>.

Inteligência Artificial

3001. A organização utiliza inteligência artificial de forma institucional em suas operações.

O uso institucional de inteligência artificial ocorre quando a organização conhece, autoriza, contrata, desenvolve ou supervisiona soluções de IA utilizadas em processos internos, atividades finalísticas ou serviços prestados ao cidadão.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização identifica e avalia continuamente oportunidades de aplicação de inteligência artificial alinhadas às suas necessidades institucionais
- ☐ b) a organização executa projetos-piloto ou provas de conceito (POC) envolvendo inteligência artificial
- ☐ c) a organização desenvolve internamente soluções de inteligência artificial para suportar suas necessidades institucionais
- ☐ d) soluções de inteligência artificial já operam em produção apoiando processos administrativos internos
- ☐ e) soluções de inteligência artificial já operam em produção apoiando atividades finalísticas ou serviços prestados diretamente ao cidadão
- ☐ f) a organização designou formalmente uma equipe, comitê ou responsáveis técnicos pelas iniciativas e projetos de inteligência artificial



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência do uso de inteligência artificial, como: relação de sistemas ou soluções com IA; projetos ou provas de conceito (POC); contratos ou aquisições; fluxos automatizados; documentos técnicos; relatórios de uso; exemplos de aplicações em processos internos ou serviços ao cidadão; ou outras evidências cabíveis, indicando a abrangência na organização.

3002. A organização estabeleceu diretrizes para o uso da inteligência artificial.

As diretrizes para uso de inteligência artificial definem regras, responsabilidades e controles para utilização segura, ética e alinhada aos objetivos da organização, incluindo aspectos como riscos, proteção de dados e supervisão humana.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização instituiu política ou norma interna com diretrizes claras para utilização ética e segura de inteligência artificial
- ☐ b) há regras e restrições formais sobre a utilização de dados institucionais não públicos, dados pessoais ou sensíveis como "insumos" (prompts) em ferramentas de IA
- ☐ c) a organização informa ao usuário, quando aplicável, que ele está interagindo com solução de inteligência artificial ou que determinado serviço, resposta ou decisão contou com apoio de IA
- ☐ d) a organização estabelece a obrigatoriedade de avaliação de riscos antes da implantação de soluções de IA
- ☐ e) a organização adota mecanismos de revisão humana, garantindo que decisões sugeridas por IA não sejam aplicadas de forma totalmente autônoma
- ☐ f) a organização realiza testes, validações ou avaliações antes da utilização institucional de soluções de IA
- ☐ g) a organização realiza ações regulares de conscientização ou capacitação sobre uso responsável de inteligência artificial



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência das diretrizes para uso de inteligência artificial, como: política, norma ou guia institucional; definição de responsabilidades; regras para uso de dados pessoais e informações sensíveis; avaliações de riscos; registros de supervisão ou revisão humana; ações de conscientização ou capacitação; atas de comitês ou grupos de trabalho; ou outras evidências cabíveis, indicando a abrangência na organização.

3003. A organização já realizou contratação de soluções ou serviços que utilizam inteligência artificial.

	Sim	Não
a) a organização contratou soluções de software como serviço (SaaS) ou plataformas que possuem funcionalidades de IA para atividades específicas (ex: análise de fraudes, reconhecimento facial, chatbots)	☐	☐
b) a organização contratou soluções de inteligência artificial generativa (ex.: ChatGPT, Gemini, Claude, Copilot ou ferramentas equivalentes)	☐	☐
c) a organização contratou serviços especializados relacionados à inteligência artificial (consultoria, treinamento, desenvolvimento ou sustentação)	☐	☐

? Considere contratações de softwares, plataformas, serviços em nuvem, assistentes virtuais, ferramentas de automação, análise de dados, IA generativa ou soluções que utilizem técnicas de inteligência artificial, aprendizado de máquina ou processamento de linguagem natural.



Evidência documental

Caso tenha assinalado que realizou contratações relacionadas à inteligência artificial, forneça alguma evidência das soluções ou serviços contratados, como: editais e/ou contratos, estudos técnicos preliminares (ETP), documentos de formalização da demanda (DFD) e número de processo SEI.

3004. Quais foram as principais dificuldades enfrentadas pela organização na fase de planejamento e contratação de soluções ou serviços que utilizam inteligência artificial (IA)?

- ☐ a) Dificuldade para identificar e comparar soluções disponíveis no mercado (fornecedores, funcionalidades, maturidade das ofertas e experiências de outros órgãos).
- ☐ b) Dificuldade para definir claramente o objeto, escopo, entregas e responsabilidades da contratação.
- ☐ c) Dificuldade para especificar requisitos técnicos e funcionais da solução (integrações, desempenho, rastreabilidade, registros de auditoria, explicabilidade ou requisitos de infraestrutura).
- ☐ d) Dificuldade para estimar preços, quantitativos ou consumo da solução (usuários, processamento, chamadas de API, armazenamento, tokens ou escalabilidade).
- ☐ e) Dificuldade para estimar o custo total da solução ao longo do tempo (implantação, operação, suporte, treinamento, segurança, monitoramento e evolução).
- ☐ f) Dificuldade para definir o modelo de contratação mais adequado (SaaS, plataforma em nuvem, desenvolvimento sob demanda, serviço gerenciado ou licenciamento).
- ☐ g) Dificuldade para definir critérios objetivos de julgamento, avaliação técnica ou comprovação de capacidade dos fornecedores.
- ☐ h) Dificuldade para elaborar artefatos de planejamento e termos de referência com requisitos e critérios verificáveis.
- ☐ i) Dificuldade para planejar implantação, integração, migração, treinamento de usuários ou gestão da mudança organizacional.
- ☐ j) Dificuldade para definir mecanismos de acompanhamento, fiscalização, transparência, auditoria ou penalidades contratuais.
- ☐ k) Dificuldade para integrar soluções de IA aos sistemas corporativos existentes.
- ☐ l) Dificuldade para definir exigências de Proteção de Dados, LGPD e garantias de que os dados do órgão não serão utilizados para treinamento de modelos públicos.

? Considere contratações de softwares, plataformas, serviços em nuvem, assistentes virtuais, ferramentas de automação, análise de dados, IA generativa ou soluções que utilizem técnicas de inteligência artificial, aprendizado de máquina ou processamento de linguagem natural.

3005. A organização adota medidas para identificar e controlar o uso não autorizado ou não mapeado de inteligência artificial generativa.

O uso não autorizado ou não mapeado de IA generativa ocorre quando agentes públicos utilizam ferramentas como ChatGPT, Gemini, Claude, Copilot ou similares em atividades de trabalho sem conhecimento, autorização, diretrizes ou supervisão institucional.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ☐ Adota em maior parte ou totalmente
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - ↳ Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização identifica quais ferramentas públicas de IA generativa (gratuitas ou contas pessoais) estão sendo acessadas na rede corporativa
- ☐ b) a organização definiu ferramentas de IA generativa autorizadas, restritas ou vedadas para uso em atividades de trabalho
- ☐ c) a organização adota controles técnicos para reduzir o uso de ferramentas de IA generativa não homologadas/autorizadas
- ☐ d) a organização possui processo para avaliação e homologação de novas ferramentas de IA necessárias às atividades de trabalho

? Considere o uso de ferramentas públicas, gratuitas, pessoais, corporativas ou integradas a suítes de produtividade, navegadores, editores de texto, sistemas de busca, atendimento, desenvolvimento de software ou análise de dados.



Evidência documental

Caso tenha assinalado que adota a prática, forneça evidência das medidas de identificação e controle do uso de IA generativa, como: levantamento de ferramentas utilizadas; norma ou orientação interna; campanhas de conscientização; registros de autorização; controles técnicos; avaliações de risco; comunicações aos usuários; ou outras evidências cabíveis.



3006. Descreva os principais usos de inteligência artificial existentes na organização, indicando, quando possível, a finalidade, a área responsável, o estágio de utilização e se a solução é desenvolvida internamente, contratada ou disponibilizada por terceiro

Resposta: _____